

AI-Simulated Role-Play: IT Compliance Decision-Making

Rosenel Roy

Department of Information Technology, University of the Cumberlands

Info Tech in a Global Economy (ITS-832-A03)

Professor John Bosire

September 13, 2026

Key Organizational Challenges Revealed During the Simulation

The simulation showed that NorthStar's compliance challenge reached beyond the 430 questionable user accounts. Baumer et al. (2026) illustrate that IAM involves cohesive processes, technologies, and authorizations and identify joiner-mover-leaver activities, timely deprovisioning, withdrawal of excessive user access, and measurable IAM process characteristics as significant components of identity lifecycle management. In this fragmented identity-governance environment, HR, IAM, business managers, and application owners did not consistently coordinate changes to workforce status. The delay in suspending user accounts, irregularities in processes executed by business units, incomplete deprovisioning, and orphaned accounts demonstrated weaknesses throughout the identity lifecycle rather than a failure in segregated access control. This perspective clarifies that correcting individual users' accounts at this stage would not resolve NorthStar's broader governance weaknesses.

Organizational circumstances can compromise regulatory compliance even when security mechanisms are in place, according to research simulations. Anthony et al. (2014) found that organizational approaches and institutional conditions affected HIPAA compliance across several U.S. hospitals. NorthStar raised this issue due to irregularities in termination of workflows, delays in executive actions to obtain approvals, and unclear duties for lifecycle events. The legacy application's preliminary audit capability imposed an additional constraint, as the organization could not rebuild activity after unauthorized access. These problems collectively demonstrated that effective compliance depends on coordinated technology, organizational processes, and accountable governance rather than on technical controls alone.

How My Responses Reflected Regulatory, Ethical, and Strategic Considerations

In my responses, I addressed regulatory concerns by systematically identifying inappropriate access to protected health information (PHI), weaknesses in deprovisioning processes, and incomplete auditability as significant risks that require thorough evaluation rather than reliance on assumptions. I distinguished between outdated accounts, confirmed authentication status after termination, and verified access to patient records to ensure an appropriate response. Blanke and McGrady (2016) demonstrate, through healthcare breach cases and a risk-management framework, the importance of recognizing vulnerabilities, evaluating security risks, and implementing effective controls and countermeasures. In alignment with this framework, I prioritized higher-risk and privileged accounts, preserved available evidence, engaged the Privacy and Legal teams when potential PHI exposure was identified, and applied HIPAA breach-assessment requirements upon confirmation of improper access to patient information.

From an ethical perspective, I focused on both patient privacy and continuity of care. I avoided disabling clinical accounts arbitrarily when legitimate access was necessary for ongoing treatment, and I did not allow operational convenience to justify unwarranted access to PHI. Instead, I enforced least-privilege restrictions, expedited account validation, established accountable ownership, and permitted time-limited exceptions. This ethical framework also informed my approach to regulatory and public communication. Looi et al. (2024) emphasize the importance of timely and reliable communication following healthcare data breaches, highlighting the need for accurate information, protective guidance, and support for affected individuals. Accordingly, I ensured that communications clearly distinguished confirmed findings from unresolved uncertainties, rather than minimizing the incident due to insufficient

evidence of external transmission. Strategically, these actions supported regulatory compliance, patient care, operational continuity, financial constraints, and organizational credibility.

Insights Gained from the AI's Feedback

The AI input support reinforced that the most significant aspect of my responses was their focus on detecting higher-risk issues, rather than treating each compliance issue as equally serious. It also highlighted how my approach progressed from analyzing individual access failures toward examining shared accountability, governance, and sustained control effectiveness. This insight is consistent with Jalali and Kaiser (2018), whose analysis of hospital cybersecurity identified endpoint complexity and internal stakeholder coordination as primary determinants of cybersecurity capability. Their findings strengthened crucial evidence from the simulation: sufficient regulatory requirements at a distinct point do not automatically establish an effective or durable security environment. Maintaining cybersecurity capability requires ongoing organizational alignment and focus after the immediate compliance issue has been addressed.

The feedback also identified areas where my approach could become more rigorous. I could have established clearer quantitative thresholds for deprovisioning timelines, unresolved exceptions, access-certification completion, and escalation. The areas needing closer attention encompassed third-party access and formal processes for managing regulatory change. Jalali and Kaiser (2018) specifically distinguish regulatory compliance from expansive cybersecurity capability, which helped me recognize that successful mitigation should not be measured solely by whether NorthStar satisfies the regulator's immediate expectations. Long-term effectiveness also requires measurable performance standards, designated accountability, objective verification, and continuity in evidence of controls that function as designed.

How I Might Revise My Approach in a Real Organizational Context

In a real organizational scenario, I would set clear, measurable identity-governance expectations well before any incident arises, rather than depending on judgment calls during remediation. Drawing on Baumer et al. (2026), who outline 43 IAM metrics spanning seven perspectives and linking IAM measurement to security, compliance, operational efficiency, and various governance audiences, I would focus on the entire identity lifecycle. This includes timely deprovisioning, preventing excessive access, eliminating orphaned identities, and managing joiner-mover-leaver processes. Building on these insights, I would define specific indicators for deprovisioning speed, orphaned accounts, unresolved access reviews, privileged-access exceptions, failed lifecycle events, and overdue certifications. By setting clear thresholds and escalation paths, management can spot weaknesses in IAM controls early and prevent potential compliance failures before they take root.

I would also reinforce organizational oversight, recognizing that automation alone cannot sustain a robust program. Jalali and Kaiser (2018) highlight the critical role of internal stakeholder alignment in hospital cybersecurity and remind us that compliance does not always guarantee security. To put this into action, I would launch regular cross-functional governance reviews that bring together IAM, HR, application owners, Security, and Compliance, all backed by independent control testing and prompt escalation of ongoing issues. Whenever major technology shifts, workforce changes, third-party integrations, or new regulations reshape the risk landscape, I would formally reevaluate controls. This proactive approach would shift the organization from simply reacting to problems to achieving continuous assurance, where control

effectiveness is constantly measured, questioned, and refined as the business and regulatory environment evolves.

References

Anthony, D. L., Appari, A., & Johnson, M. E. (2014). Institutionalizing HIPAA compliance: Organizations and competing logics in U.S. health care. *Journal of Health and Social Behavior*, 55(1), 108–124. <https://doi.org/10.1177/0022146513520431>

Baumer, T., Kern, S., Fuchs, L., & Pernul, G. (2026). Identity and access management metrics: A systematic review. *ACM Computing Surveys*, 58(8), Article 213. <https://doi.org/10.1145/3788858>

Blanke, S. J., & McGrady, E. (2016). When it comes to securing patient health information from breaches, your best medicine is a dose of prevention: A cybersecurity risk assessment checklist. *Journal of Healthcare Risk Management*, 36(1), 14–24. <https://doi.org/10.1002/jhrm.21230>

Jalali, M. S., & Kaiser, J. P. (2018). Cybersecurity in hospitals: A systematic, organizational perspective. *Journal of Medical Internet Research*, 20(5), e10059. <https://doi.org/10.2196/10059>

Looi, J. C. L., Allison, S., Bastiampillai, T., Maguire, P. A., Kisely, S., & Looi, R. C. H. (2024). Healthcare provider data breaches – framework for crisis communication and support of patients and healthcare workers in mental healthcare. *Australasian Psychiatry*, 32(4), 319–322. <https://doi.org/10.1177/10398562241261818>

AI Disclosure: I used ChatGPT (OpenAI) to support brainstorming, organize role-play and reflective analysis, and identify relevant peer-reviewed scholarly sources. I connected the analysis to my own professional experience in identity and access management, particularly in navigating access governance, compliance requirements, and user access review practices, and

selected research that aligned with those real-world observations. I have reviewed, paraphrased, and verified the final content and citations before submission.